

ACTIVIDAD 08 DE 46 - ESCANEO DE SEGURIDAD WEB CON OWASP ZAP

Segunda hora de clase (50 minutos) | Trabajo practico asistido con IA

Herramienta principal: opencode (CLI). Alternativas: ChatGPT, Claude, Copilot, Gemini.

Base normativa / marco de referencia: OWASP Top 10 y OWASP ZAP; evaluacion de riesgos GR.2 (Marco Agesic)

1. Contexto

Hasta ahora analizaste el código (SAST). Hoy usas un analizador dinámico (DAST): OWASP ZAP, una herramienta gratuita que escanea aplicaciones web en ejecución. Levantarás tu API de la Actividad 4 y la escanearás para descubrir vulnerabilidades reales, clasificándolas por severidad.

2. Marco teorico

¿Que es el analisis dinamico (DAST)?

DAST (Dynamic Application Security Testing) prueba la aplicación EN EJECUCION: le envía peticiones reales y observa como responde, igual que lo haría un atacante.

- Complementa al SAST (actividad 5): ve el comportamiento, no el código.

OWASP ZAP

ZAP (Zed Attack Proxy) es una herramienta gratuita de pruebas de seguridad web: actúa como proxy entre tu navegador y la aplicación.

- Spider: recorre la aplicación descubriendo URLs.
- Escaneo activo: envía ataques (inyección, XSS) y reporta.
- Reporte: lista de hallazgos con severidad y recomendaciones.

Importante

- Solo se escanea lo que está autorizado (tu propio laboratorio).
- El DAST encuentra problemas reales en ejecución que el SAST no ve.

3. Objetivos de aprendizaje

- Instalar y configurar OWASP ZAP.
- Levantar la API local y escanearla (spider + active scan).
- Interpretar alertas por severidad y mapearlas al OWASP Top 10.

- Exportar el reporte de ZAP como evidencia.

4. Herramientas del día (instalacion paso a paso)

OWASP ZAP (Zed Attack Proxy, gratuito)

Proxy de seguridad web que encuentra vulnerabilidades en aplicaciones en ejecucion. Es el estandar libre del OWASP.

1. Descarga desde <https://www.zaproxy.org> (requiere Java instalado).
2. Instala el paquete de 64 bits y abre ZAP.
3. Acepta la configuracion por defecto (modo de escaneo persistente).

API de la Actividad 4

El objetivo del escaneo sera tu API Flask corriendo en localhost:5000.

4. Activa el entorno virtual de la Actividad 4 y ejecuta ``python app.py``.
5. Verifica con ``curl http://localhost:5000/health``.

5. Desarrollo paso a paso

Paso 1: Levantar la API

Ejecuta tu API de la Actividad 4 y dejala corriendo.

Paso 2: Configurar ZAP

En ZAP, configura el navegador o usa "Quick Start" con la URL `http://localhost:5000`.

Paso 3: Spider

Ejecuta el spider para descubrir las rutas de la aplicacion.

Paso 4: Active Scan

Ejecuta el active scan sobre la API y espera a que termine.

Paso 5: Interpretar alertas

Revisa las alertas por severidad (Alta/Media/Baja) y pide a la IA que explique cada una.

Paso 6: Mapear a OWASP Top 10

Asocia cada alerta con su categoria del OWASP Top 10.

Paso 7: Exportar reporte

Exporta el reporte de ZAP (HTML o JSON) y guardalo en evidencias/.

Paso 8: Documentar y reflexionar

Escribe el informe y tu reflexion.

6. Prompts sugeridos para la IA (opencode)

Copia y adapta estos mensajes en opencode (comando interactivo o `opencode` en terminal).

Explicame estas alertas de OWASP ZAP: [pega el listado]. ¿Que riesgo representa cada una, a que categoria del OWASP Top 10 pertenece y como se corrige en Flask?

Dame un plan de remediacion priorizado para las alertas de un escaneo DAST de una API financiera.

¿En que se diferencia un analisis SAST (Bandit, Semgrep) de un DAST (ZAP)?
¿Que descubrio ZAP que las otras herramientas no podian ver?

7. Documentacion del RSI (bitacora)

Registra en `bitacora.md` de la carpeta de la actividad:

- Alertas encontradas y su severidad.
- Asociacion alerta-categoria OWASP Top 10.
- Plan de remediacion (prioridad).
- Reporte exportado y guardado.

8. Evidencias a capturar y guardar

Guarda cada evidencia en la carpeta `evidencias/` con el nombre EVI-YYYY-MM-DD-NN-descripcion.ext y registrala en la bitacora.

- EVI-...-01-zap-alertas.png (listado de alertas por severidad).
- EVI-...-02-zap-reporte.html (reporte exportado).
- EVI-...-03-owasp-mapa.png (alertas mapeadas al Top 10 con IA).
- EVI-...-04-remediacion.png (plan de remediacion).

9. Informe segun el marco de referencia

Elabora el informe de la actividad (archivo `informe.md`) que incluya:

- Metodologia (DAST con ZAP).
- Hallazgos por severidad y categoria OWASP.
- Comparacion SAST vs DAST.
- Plan de remediacion priorizado.

10. Entregable de la clase

Reporte de ZAP exportado + alertas interpretadas + plan de remediacion + evidencias.

Anexo A - Informe completo para presentar al BCU

Plantilla del informe ejecutivo que el RSI entregaria al Banco Central del Uruguay (BCU) por la actividad 08 - Escaneo de seguridad web con OWASP ZAP. Completa los campos [entre corchetes] con los resultados reales de la actividad y adjunta las evidencias EVI-...

Encabezado del informe

Institucion: Banco Ficticio del Uruguay

Responsable de Seguridad de la Informacion (RSI): [Nombre y cargo]

Destinatario: Banco Central del Uruguay - Superintendencia de Instituciones Financieras

Asunto: Actividad 08 - Escaneo de seguridad web con OWASP ZAP

Fecha: [dd/mm/aaaa] | Version: 1.0 | Clasificacion: Confidencial

1. Resumen ejecutivo

[2 a 5 parrafos breves: que se realizo, en que marco normativo, que se encontro, que se corrigio y el estado actual. Debe poder leerse en 1 minuto por un directivo.]

2. Marco normativo y regulatorio aplicable

- Norma de Seguridad de la Informacion y Ciberseguridad del BCU (SF.SEG.08).
- Recopilacion de Normas de Regulacion y Control del Sistema Financiero (RNRCSF).
- Circular sobre gestion de incidentes y notificacion de eventos de ciberseguridad.
- Normativa interna del Banco Ficticio del Uruguay: [politica de seguridad, plan de trabajo RSI].

3. Alcance y metodologia

- Alcance: [activos, procesos, sistemas o areas cubiertos por la actividad].
- Metodo: [pruebas tecnicas, revision documental, simulacion, escaneo, etc.].
- Herramientas utilizadas: OWASP ZAP (Zed Attack Proxy, gratuito), API de la Actividad 4.
- Periodo de ejecucion: [fecha de inicio] a [fecha de fin].

4. Descripcion de la actividad

Hasta ahora analizaste el codigo (SAST). Hoy usas un analizador dinamico (DAST): OWASP ZAP, una herramienta gratuita que escanea aplicaciones web en ejecucion. Levantaras tu API de la Actividad 4 y la escanearas para descubrir vulnerabilidades reales, clasificandolas por severidad.

5. Resultados obtenidos

- Objetivo: Instalar y configurar OWASP ZAP. -> [Logrado / Parcial / No logrado]

- Objetivo: Levantar la API local y escanearla (spider + active scan). -> [Logrado / Parcial / No logrado]
- Objetivo: Interpretar alertas por severidad y mapearlas al OWASP Top 10. -> [Logrado / Parcial / No logrado]
- Objetivo: Exportar el reporte de ZAP como evidencia. -> [Logrado / Parcial / No logrado]

6. Riesgos identificados y evaluacion

Tabla de riesgos detectados con impacto en la institucion financiera:

ID Riesgo	Descripcion	Probabilidad	Impacto	Nivel	Tratamiento
R-01	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]
R-02	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]

7. Controles implementados

Descripcion de los controles aplicados y su estado:

- Control: Instala y configura ZAP -> [Implementado / Parcial / Pendiente]
- Control: Escanea la API local correctamente -> [Implementado / Parcial / Pendiente]
- Control: Interpreta alertas y las asocia al OWASP Top 10 -> [Implementado / Parcial / Pendiente]
- Control: Exporta y guarda el reporte -> [Implementado / Parcial / Pendiente]
- Control: Elabora un plan de remediacion -> [Implementado / Parcial / Pendiente]

8. Incidentes de seguridad relacionados

[Ninguno en esta actividad. O bien: fecha, tipo, clasificacion, datos afectados, impacto y medidas adoptadas. Si corresponde, nota que ya se notifico al BCU en los plazos reglamentarios.]

9. Indicadores y metricas de la actividad

- Tiempo de ejecucion: [X] horas.
- Hallazgos: [X] altos, [X] medios, [X] bajos.
- Hallazgos corregidos: [X] / [X].
- Cobertura: [X]% de los activos del alcance.

10. Plan de accion y proximos pasos

Accion	Responsable	Plazo	Estado
[accion pendiente]	[cargo]	[dd/mm/aaaa]	Pendiente

11. Conclusion

[Conclusion ejecutiva: postura de seguridad de la institucion tras la actividad y compromiso de seguimiento.]

12. Firma y aprobacion

Firma del RSI: _____ Fecha: [dd/mm/aaaa]

Visto bueno del area de negocio / Direccion: _____

Anexos: evidencias EVI-... registradas en la bitacora.

Anexo B - Como presentar la actividad a AGESIC

Guia de estructura y contenido para comunicar la actividad 08 - Escaneo de seguridad web con OWASP ZAP a la Agencia para el Desarrollo del Gobierno de Gestion Electronica y la Sociedad de la Informacion (AGESIC), alineada al marco de ciberseguridad de referencia para Uruguay.

Encuadre institucional

- Organismo: Banco Ficticio del Uruguay, dependencia publica.
- RSI: [Nombre y cargo] | Correo: [correo institucional].
- Fecha de presentacion: [dd/mm/aaaa] | Periodo cubierto: [periodo].

1. Presentacion del responsable

Quien es el RSI, su rol, a que direccion reporta y como se vincula con la gestion de la seguridad de la informacion en el Banco Ficticio del Uruguay.

2. Objetivo de la actividad

Hasta ahora analizaste el codigo (SAST). Hoy usas un analizador dinamico (DAST): OWASP ZAP, una herramienta gratuita que escanea aplicaciones web en ejecucion. Levantarás tu API de la Actividad 4 y la escanearas para descubrir vulnerabilidades reales, clasificandolas por severidad.

- Objetivo: Instalar y configurar OWASP ZAP.
- Objetivo: Levantar la API local y escanearla (spider + active scan).
- Objetivo: Interpretar alertas por severidad y mapearlas al OWASP Top 10.
- Objetivo: Exportar el reporte de ZAP como evidencia.

3. Marco de referencia utilizado

- Marco normativo de ciberseguridad aplicable (AGESIC / normativa nacional).
- Ley 18.331 de Proteccion de Datos Personales y su Decreto Reglamentario.
- Guia o documento de base: OWASP Top 10 y OWASP ZAP; evaluacion de riesgos GR.2 (Marco Agesic)
- Estandares de buenas practicas: [ISO/IEC 27001, NIST CSF, OWASP, etc.].

4. Metodologia y herramientas

Como se desarrollo la actividad y con que herramientas (OWASP ZAP (Zed Attack Proxy, gratuito), API de la Actividad 4).

5. Resultados y evidencias

Descripcion de lo obtenido, con referencia a las evidencias guardadas:

- Evidencia: EVI-...-01-zap-alertas.png (listado de alertas por severidad).
- Evidencia: EVI-...-02-zap-reporte.html (reporte exportado).
- Evidencia: EVI-...-03-owasp-mapa.png (alertas mapeadas al Top 10 con IA).
- Evidencia: EVI-...-04-remediacion.png (plan de remediacion).

6. Hallazgos, riesgos y recomendaciones

Presentacion de hallazgos ordenados por criticidad y las recomendaciones asociadas:

ID	Hallazgo	Criticidad	Recomendacion	Estado
H-01	[hallazgo]	[C/A/M/B]	[recomendacion]	[Abierto / Cerrado]

7. Gestion de incidentes (si aplica)

- Tipificacion del evento y datos involucrados.
- Notificacion a la Unidad Reguladora y de Control de Datos Personales si se vieron afectados datos personales.
- Lecciones aprendidas y mejoras al plan de respuesta.

8. Plan de mejora y continuidad

Mejora planificada	Responsable	Plazo	Prioridad
[mejora]	[cargo]	[dd/mm/aaaa]	[A/M/B]

9. Compromisos y firmas

El Banco Ficticio del Uruguay se compromete a [seguimiento, capacitacion, revision periodica] y presenta este informe para conocimiento de AGESIC.

Firma del RSI: _____ Sello del organismo: _____

11. Rubrica de evaluacion

Criterio	Logrado (3)	En desarrollo (2)	No logrado (1)
Instala y configura ZAP			
Escanea la API local correctamente			
Interpreta alertas y las asocia al OWASP Top 10			
Exporta y guarda el reporte			
Elabora un plan de remediacion			

12. Checklist de cierre

- [] Escaneé la API con ZAP.
- [] Interpreté al menos 3 alertas.

- [] Exporté el reporte a evidencias/.

13. Reflexion sobre el uso de IA

¿Por que conviene combinar SAST y DAST? ¿Que vulnerabilidades de tu API solo aparecen cuando se ejecuta?